

JPMorgan Chase 2014: GRC Case Study

Instructor Guide and Answer Key

Girish Nair

Instructor Guide and Answer Key

Instructor Overview

This simulation is designed for students with no or limited IT experience. The sequence begins with plain-language comprehension and gradually introduces asset governance, risk statements, control mapping, corrective actions, monitoring and executive communication.

How this fits with the team's workflow: this instructor guide, the workbook and the task sheets define what students must produce and why, and hold the model answers. The team's shared task tracker (any board or checklist) defines who does each part, in what order, and when a task is ready for instructor review. Brief students on this split before Task 1.

Task	Skill developed	Suggested release
1	Understand the Case and Learn the Basic Terms	Release after prior task checkpoint
2	Build the Incident Timeline and Identify Stakeholders	Release after prior task checkpoint
3	Create an Asset Inventory and Define Control Scope	Release after prior task checkpoint
4	Identify Risks and Write Clear Risk Statements	Release after prior task checkpoint
5	Assess and Prioritize the Risks	Release after prior task checkpoint
6	Map the Gaps to GRC Frameworks and Requirements	Release after prior task checkpoint
7	Design the Corrective Action and Exception Management Plan	Release after prior task checkpoint
8	Create KRIs, KPIs and an Ongoing Monitoring Dashboard	Release after prior task checkpoint
9	Conduct the Incident Tabletop and Present to Executives	Release after prior task checkpoint

Suggested Six-Student Role Model

Student	Role	Primary responsibilities
1	GRC Coordinator	Organizes work, consolidates submissions, manages actions and prepares executive reporting.
2	Asset and Control Analyst	Owns inventory, control scope, MFA and network-control analysis.
3	Risk Analyst	Writes risk statements, scores risks and maintains the risk register.
4	Compliance and Controls Analyst	Maps requirements, identifies evidence and assesses compliance gaps.
5	Incident and Communications Analyst	Builds the timeline, tabletop decisions and stakeholder communication.
6	Internal Auditor / Quality Reviewer	Challenges evidence, scoring, ownership and closure; preserves independence.

For smaller classes

One student can complete the simulation individually, or teams of three can combine roles 1+5, 2+3 and 4+6. For larger classes, create several teams and compare their risk decisions.

Suggested Delivery Plan

Week	Tasks	Instructor emphasis
1	Tasks 1-2	Facts, terminology, timeline and stakeholders.
2	Tasks 3-4	Asset scope, control gaps and business risk statements.
3	Tasks 5-6	Risk scoring, evidence and framework mapping.
4	Tasks 7-8	Corrective actions, exceptions, metrics and escalation.
5	Task 9 + final presentation (capstone)	Tabletop, executive report and Risk Committee presentation.

Beginner teaching rule

Do not test students on technical configuration details. Grade their ability to identify ownership, scope, evidence, risk, control intent, escalation and management decisions.

General Answer-Key Principles

- Accept alternative answers when they are evidence-based, internally consistent and written in plain language.
- Do not require students to memorize control identifiers. They should explain what the control is intended to achieve.
- Challenge statements such as 'buy a better tool' unless the student also addresses inventory, ownership, process, exceptions and assurance.
- Require every proposed closure to include evidence and independent validation.
- Where the case is uncertain, reward students who explicitly state what must be verified.

Task 1: Understand the Case and Learn the Basic Terms

Suggested time: 60-75 minutes · **Primary lead:** GRC Coordinator

Required outputs
Case fact sheet; glossary check; 150-word breach summary; five questions for the instructor.

Facilitation notes

- Ask students to explain the case without using the words 'hackers were sophisticated.' The main lesson is control coverage.
- Correct the misconception that contact data has no value. It can support targeted phishing, identity fraud and social engineering.

Model answers

Model 150-word summary

In 2014, attackers entered JPMorgan Chase through the Corporate Challenge microsite, an internet-facing system that was connected to the bank but managed outside the core technology organization. The server had not been included in the enterprise two-factor authentication upgrade, so stolen employee credentials were sufficient to log in. Attackers then moved through the internal network and accessed about 90 servers. They obtained names, addresses, phone numbers and email addresses relating to 76 million households and 7 million small businesses. Investigators did not confirm theft of account numbers, passwords, Social Security numbers or other financial account data. The case is a GRC failure because the organization had a security policy and significant security resources, but its asset inventory and exception process did not ensure that every in-scope system received the required control. The core lesson is that control coverage and governance completeness matter as much as technology investment.

Question answers

Question / topic	Model answer
Who was affected?	Approximately 76 million households and 7 million small businesses.
What was accessed?	Names, addresses, phone numbers and email addresses.
What was not confirmed stolen?	Financial account data, account numbers, passwords and Social Security numbers.

Question / topic	Model answer
Initial entry point	The JPMorgan Corporate Challenge microsite server.
Missing control	Two-factor authentication / multi-factor authentication.
Why governance failure?	The policy and technology existed, but the organization did not maintain complete scope, track the exception, assign compensating controls or escalate the overdue gap.
Fact vs assumption	A fact is directly supported by the case or evidence. An assumption is a reasonable possibility that still requires validation.

Strong investigation questions

- Who owned the Corporate Challenge server and who approved its connection to the internal network?
- When was the server created, and why was it omitted from the asset inventory?
- Was a formal MFA exception recorded, approved and assigned an expiration date?
- What firewall rules or trust relationships allowed access from the microsite to internal systems?
- Which logs first detected the attack, and why did detection take six to eight weeks?

Task 2: Build the Incident Timeline and Identify Stakeholders

Suggested time: 75 minutes · **Primary lead:** Incident and Communications Analyst

Required outputs

Incident timeline; stakeholder map; responsibility and information-needs table.

Facilitation notes

- Stress that incident response is cross-functional. The SOC cannot make legal disclosure or business-shutdown decisions alone.
- Use the timeline to show the difference between compromise date, discovery date, containment date and disclosure date.

Model answers

Model incident timeline

Date / period	Event	Category
Spring 2014	Attackers researched public-facing systems and identified the Corporate Challenge microsite.	Attack activity
June 2014	Attackers used stolen employee credentials to log in to the microsite server, which lacked 2FA.	Attack activity
June-July 2014	Attackers moved laterally, accessed about 90 servers and reached a customer contact database.	Attack activity
Late July 2014	Security monitoring identified suspicious activity and an internal investigation began.	Detection
August 2014	The breach was confirmed and contained; FBI and forensic investigators were involved.	Response
October 2014	JPMorgan publicly disclosed the breach through an SEC filing.	Disclosure
2015-2019	Attackers were indicted, prosecuted and convicted or pleaded guilty.	Legal follow-up

Model stakeholder map

Stakeholder	Role / information need
CISO / Security leadership	Direct containment and risk decisions; brief executives.
SOC / Incident Response	Investigate alerts, contain access, preserve evidence and coordinate forensics.
Asset owner / Corporate Challenge team	Provide system details, business need, credentials, vendors and change history.
Infrastructure / Network team	Disable access, review connections, segment systems and preserve logs.
Identity and Access Management	Reset credentials, enforce MFA and review privileged access.
Legal and Compliance	Assess disclosure, law-enforcement, contractual and regulatory obligations.
Privacy	Assess affected data and customer privacy impact.
Executive management / Board	Approve major risk and communication decisions.
FBI / Law enforcement	Investigate criminal activity.
Customers and small businesses	Receive accurate information and protective guidance when appropriate.
SEC and banking regulators	Receive required disclosures and supervisory information.

Missed-intervention points

- Before the breach: register the microsite, apply MFA, conduct a security review and isolate it from internal customer systems.
- During the breach: alert on unusual authentication, cross-zone connections and bulk data access within hours rather than weeks.

Task 3: Create an Asset Inventory and Define Control Scope

Suggested time: 90 minutes · **Primary lead:** Asset and Control Analyst

Required outputs

Simplified asset inventory; ownership gaps; control-scope statement; inventory completeness checks.

Facilitation notes

- Emphasize that 'business owned' does not mean 'outside security scope.'
- Ask how the organization can independently verify completeness rather than relying only on self-reporting.

Model answers

Model asset inventory

Asset	Business owner	Technical owner	Data	Internet	Criticality	Applicable controls
Corporate Challenge microsite server	Corporate events/marketing	Web/Infrastructure team	Employee credentials; website data	Yes	High exposure	MFA, patching, vulnerability scanning, logging, segmentation
Employee user account	Employee's manager	Identity and Access Management	Authentication credentials	Indirect	High	MFA, password controls, monitoring, access review
Internal network	Technology Operations	Network Security	Traffic between systems	No, but connected	Critical	Segmentation, firewall rules, monitoring
Customer contact database	Retail/Small Business Banking	Database/Application team	Names, addresses, phone numbers,	No	Critical	Access control, encryption, logging, data-

Asset	Business owner	Technical owner	Data	Internet	Criticality	Applicable controls
			email addresses			loss monitoring
Security monitoring / SIEM	Security Operations	SOC Engineering	System and security logs	No	Critical	Log coverage, alert use cases, retention
MFA platform	Identity Security	IAM Engineering	Authentication factors and access decisions	No	Critical	Enrollment coverage, exception tracking, availability
Firewall / network gateways	Network Security	Network Engineering	Connectivity rules	Boundary	Critical	Rule approval, periodic review, deny-by-default

Model control-scope statement

All workforce accounts and all systems that are internet-facing, remotely accessible, connected to the corporate network, or capable of reaching customer or confidential data must use MFA where technically supported. Any exclusion must be recorded as a formal exception with an owner, compensating controls, approval and expiration date. All such systems must also be included in vulnerability scanning and patch management.

Inventory completeness tests

- Reconcile the managed inventory with automated network discovery results every month.
- Compare DNS records, cloud resources and internet-facing domain lists with the inventory.
- Require new projects, web properties and vendor connections to register assets before launch.
- Review firewall rules, certificates and IP address allocations to identify unknown systems.
- Have business units certify their assets quarterly and investigate unowned systems.

Question answers

Question / topic	Model answer
Why easy to miss?	It was purpose-built, managed outside central IT, perceived as low criticality and may have existed outside normal provisioning.
Registration accountability	The commissioning business owner is accountable; IT/security validates and records the asset.

Question / topic	Model answer
Low-criticality website controls	Yes. Internet exposure and connectivity, not only business purpose, determine security scope.
How test completeness?	Reconcile independent discovery sources to the managed inventory and investigate every mismatch.

Task 4: Identify Risks and Write Clear Risk Statements

Suggested time: 90 minutes · **Primary lead:** Risk Analyst

Required outputs

Six cause-event-impact risk statements; control-gap table; risk owners.

Facilitation notes

- Reject single-word risks such as 'MFA risk.' Require cause, event and impact.
- Separate risk owner from control operator. The executive owns the business risk; technical teams operate controls.

Model answers

Model risk register - identification stage

ID	Model risk statement	Control gap	Risk owner	CIA
R1	Because the asset inventory is incomplete, internet-facing systems may be omitted from mandatory security programs, resulting in unauthorized access, data exposure, regulatory criticism and reputational harm.	Asset inventory and reconciliation	CIO / Technology Risk Executive	Confidentiality, Integrity, Availability
R2	Because MFA exceptions are not formally tracked and escalated, attackers using stolen passwords may access corporate systems, resulting in account compromise and unauthorized network entry.	MFA coverage and exception management	CISO / Head of Identity Security	Confidentiality, Integrity
R3	Because business-managed microsites are commissioned outside standard security governance, vulnerable internet-facing systems may be launched or retained, resulting in an expanded attack surface and control noncompliance.	Secure onboarding and web-property registration	Business unit executive	Confidentiality, Integrity, Availability
R4	Because network segmentation and cross-zone access controls are insufficient, an attacker compromising a low-criticality web server may	Network segmentation and	Head of Network Security	Confidentiality, Integrity, Availability

ID	Model risk statement	Control gap	Risk owner	CIA
	move to customer systems, resulting in large-scale data exposure and operational disruption.	firewall governance		
R5	Because monitoring rules do not identify unusual authentication, lateral movement and bulk data access quickly enough, attackers may remain undetected for weeks, resulting in greater data loss and investigation cost.	Security logging, SIEM coverage and alerting	SOC Director	Confidentiality, Integrity
R6	Because security program effectiveness is measured mainly by tools and spending rather than control coverage, management may receive false assurance, resulting in unaddressed exceptions and repeated control failures.	Coverage assurance and governance reporting	CISO / Enterprise Risk Committee	All

Question answers

Question / topic	Model answer
No MFA	It is a control gap. The risk is what could happen because the control is missing.
Asset inventory impacts	Missed patching, missed MFA, missed monitoring, unknown data exposure, compliance gaps and delayed incident response.
Business owner role	The business owner creates or uses the service, understands the business need and impact, and must accept or fund risk decisions.

Task 5: Assess and Prioritize the Risks

Suggested time: 90 minutes · **Primary lead:** Risk Analyst with Internal Auditor review

Required outputs

Completed risk register (likelihood x impact, score and rating); priority list; scoring rationale; audit challenge notes.

Facilitation notes

- Scores are not facts. Require written rationale and challenge consistency.
- Allow different scores if supported by data classification, threat information and risk appetite.

Model answers

Likelihood Scale

Rating	Description	Beginner-friendly guide
1	Rare	No known occurrence and strong preventive controls.
2	Unlikely	Possible, but limited evidence and good controls.
3	Possible	Could occur; examples exist in the industry.
4	Likely	Has occurred internally or controls are materially weak.
5	Almost Certain	Is occurring, recently occurred or is expected repeatedly.

Impact Scale

Rating	Description	Beginner-friendly guide
1	Insignificant	Little disruption; no sensitive data or regulatory effect.
2	Minor	Limited users or short disruption; easily corrected.
3	Moderate	Noticeable business impact, internal escalation or limited sensitive data.
4	Major	Large customer impact, significant operational disruption or likely regulatory scrutiny.
5	Critical	Very large data exposure, severe financial/reputational harm or threat to major services.

Scoring formula

Inherent risk score = Likelihood x Impact. Use the case evidence and document the reason for every score.

Model risk scoring

ID	Risk	L	I	Score	Rating	Rationale
R1	Incomplete asset inventory	4	5	20	Critical	The missed asset demonstrates likely recurrence without systemic correction.
R2	Untracked MFA exception	5	5	25	Critical	The event occurred and enabled initial access; customer exposure was severe.
R3	Business-managed portal governance	4	4	16	High	Similar portals may exist and can create internet-facing gaps.
R4	Insufficient network segmentation	4	5	20	Critical	Attackers reached about 90 servers and a large customer database.
R5	Delayed detection	4	4	16	High	Six-to-eight week dwell time allowed broad access.
R6	Coverage assurance weakness	4	4	16	High	Management can receive false assurance across multiple control programs.

Recommended priorities

- Priority 1: R2 - close all externally accessible MFA exceptions and apply compensating controls immediately.
- Priority 2: R4 - isolate internet-facing systems and remove unnecessary connectivity to customer-data zones.
- Priority 3: R1 - establish inventory reconciliation so other unknown assets are identified.

Model scoring challenges

- Challenge: R1 likelihood could be 5 because one missed asset proves the process failed. Final decision: 4, because the number of other unknown assets is not established; increase to 5 if discovery identifies widespread omissions.
- Challenge: R5 impact could be 5 due to 83 million affected customer and business relationships. Final decision: 4 because contact data, not financial credentials, was accessed; increase to 5 if financial data or fraud is confirmed.

Question answers

Question / topic	Model answer
Why R2/R4 high?	They directly enabled access and expansion of the breach and involved highly sensitive customer systems.
Same score, different urgency?	Yes. Active exploitation, regulatory deadlines, available quick fixes and concentration risk can change urgency.
Evidence changes score	New incidents, control testing, discovery results, data classification, financial-loss estimates and threat intelligence.

Task 6: Map the Gaps to GRC Frameworks and Requirements

Suggested time: 90 minutes · **Primary lead:** Compliance and Controls Analyst

Required outputs

NIST CSF gap map; simplified regulatory mapping; evidence list; compliance conclusion.

Facilitation notes

- Students should map the case to control purposes, not simply copy framework names.
- Discuss policy design versus operating effectiveness and why auditors request evidence.

Model answers

Model NIST CSF assessment

Function	Assessment	Rationale
Identify	Partial / Gap	The asset inventory was incomplete and did not include the microsite or its connectivity path.
Protect	Partial / Gap	MFA was broadly deployed but not applied to the breached server; segmentation and compensating controls were inadequate.
Detect	Adequate but needs improvement	Internal monitoring detected the breach in six to eight weeks, better than the historical industry average but too late to prevent broad access.
Respond	Effective	The bank investigated, engaged forensics and law enforcement, contained the breach and closed the vulnerability.
Recover	Effective	No financial credentials were confirmed stolen; the bank restored control and increased security investment.

Model regulatory mapping

Requirement	Model implication
FFIEC cyber risk management	Requires comprehensive asset and risk management; the omitted internet-facing server shows incomplete scope.

Requirement	Model implication
FFIEC authentication guidance	Supports MFA for high-risk and remote access; a single-factor internet-facing server was inconsistent with the expected control.
GLBA Safeguards Rule	Requires a comprehensive information-security program covering customer information systems; the access path to customer records showed a coverage gap.
OCC Heightened Standards	Large banks are expected to maintain strong front-line risk governance; the missed system and unmanaged exception indicate weak execution.
SEC disclosure context	Under current rules, a material incident generally requires Form 8-K disclosure within four business days after determining materiality, rather than waiting for a routine quarterly filing.

Evidence request list

- Asset inventory and asset-owner certification records.
- Network discovery and inventory-reconciliation reports.
- MFA enrollment report and exception register.
- Vulnerability scan and patch-compliance reports.
- Firewall diagrams, rules and approval records.
- SIEM log-source coverage and alert-use-case documentation.
- Incident tickets, forensic report and containment records.
- Risk committee minutes and executive approvals.
- SEC filing and regulatory communication records.

Model compliance conclusion

The organization had mature capabilities and policies, but evidence shows material gaps in control coverage and exception governance. Identify and Protect were not fully effective because the inventory, MFA scope and segmentation controls did not cover every relevant system. Detect, Respond and Recover functioned more effectively, limiting the incident after discovery. The compliance concern is therefore not absence of a program, but incomplete implementation and insufficient assurance that mandatory controls applied to all in-scope assets.

Question answers

Question / topic	Model answer
Weakest functions	Identify and Protect.
Functions that worked	Respond and Recover, with Detect relatively adequate.
Why evidence?	A policy shows intent; evidence shows the control was actually implemented, complete and operating.
Current SEC difference	A material incident would generally be disclosed on Form 8-K within four business days after materiality is determined.

Task 7: Design the Corrective Action and Exception Management Plan

Suggested time: 105 minutes · **Primary lead:** GRC Coordinator and Control Owners

Required outputs

30-60-90 day corrective-action plan; exception register; RACI; residual-risk decisions.

Facilitation notes

- A corrective action such as 'improve security' is not acceptable. Require a specific change, owner, due date and evidence.
- The person implementing a fix should not be the only person validating closure.

Model answers

Model 30-60-90 day plan

Timeframe	Action	Owner	Evidence
0-30 days	Disable or restrict the compromised access path; enforce MFA; reset credentials; isolate the microsite; review all internet-facing MFA exceptions.	CISO, IAM, Network Security	MFA coverage report, firewall change, incident ticket, exception list
0-30 days	Run discovery of internet-facing assets and reconcile with the inventory.	Infrastructure Asset Management	Discovery report and unmatched-asset log
31-60 days	Register all web properties, assign business and technical owners and classify data/connectivity.	Business Technology Governance	Approved inventory and owner certifications
31-60 days	Review cross-zone firewall rules and remove unjustified paths from internet-facing systems to customer-data zones.	Network Security	Approved rule review and updated diagram
31-60 days	Implement SIEM alerts for unusual authentication, lateral movement and bulk data access.	SOC Engineering	Use-case test results and alert tickets
61-90 days	Establish monthly inventory reconciliation and quarterly business certification.	CIO / GRC	Operating procedure, dashboard and first

Timeframe	Action	Owner	Evidence
			completed review
61-90 days	Implement formal exception governance with aging thresholds and executive escalation.	CISO / Technology Risk	Exception policy, register and committee minutes
61-90 days	Conduct independent testing of MFA, asset coverage and segmentation actions.	Internal Audit / Second Line Risk	Validation report and closure recommendation

Model exception-register entry

Field	Model entry
ID	EX-2014-001
Control	MFA required for internet-facing corporate systems
Asset	Corporate Challenge microsite server
Reason	Legacy application not integrated with enterprise MFA
Owner	Corporate Events Technology Owner
Risk	Stolen password could permit unauthorized entry and lateral movement
Compensating controls	Restrict access by source, monitor every login, disable unnecessary accounts, isolate network segment, daily log review
Due date	Within 30 days
Approvers	Business Executive, CISO and Technology Risk
Status	Open - Critical
Escalation	Immediate CISO notification; executive approval if not closed by due date
Closure evidence	MFA test, updated inventory, access review and independent validation

Model RACI

Activity	Responsible	Accountable	Consulted	Informed
Register new asset	Business owner	Business executive	Asset Management, Security	GRC, Internal Audit
Assess required controls	Security Architecture	CISO delegate	Business owner, Privacy	GRC
Approve exception	GRC prepares	CISO / Business executive	Legal, Risk owner	Internal Audit
Implement remediation	Technical control owner	Risk owner	GRC, Vendor	Executive management

Activity	Responsible	Accountable	Consulted	Informed
Validate closure	Second Line Risk / Internal Audit	Chief Risk or Audit authority	Control owner	Risk Committee

Residual-risk statement

After MFA enforcement, segmentation, inventory reconciliation and monitoring improvements, R2 may reduce from Critical (25) to Moderate (6: likelihood 2, impact 3). The business risk owner may accept the remaining exposure only after independent validation and documented approval by the CISO or delegated risk committee.

Question answers

Question / topic	Model answer
Measurable action	It states exactly what will change, who owns it, when it is due, what success means and what evidence proves completion.
Exception contents	Control, asset, reason, risk, owner, compensating controls, approvals, start and end dates, status, escalation and closure evidence.
Higher approval	Internet-facing gaps are easier to exploit and can expose the broader enterprise, so risk tolerance is lower.
Closure validation	A function independent of implementation, such as second-line risk, control assurance or Internal Audit.

Task 8: Create KRIs, KPIs and an Ongoing Monitoring Dashboard

Suggested time: 90 minutes · **Primary lead:** GRC Reporting Analyst

Required outputs

KPI/KRI catalog; dashboard; thresholds; reporting and escalation schedule.

Facilitation notes

- Distinguish a KPI, which measures performance, from a KRI, which signals exposure.
- Ask whether the dashboard would have identified the missed server before the breach.

Model answers

Model metric catalog

Type	Metric	Calculation	Target	Threshold	Owner	Frequency
KPI	Asset inventory reconciliation completion	% monthly reconciliations completed by due date	100%	<100%	Asset Management	Monthly
KPI	MFA coverage	% in-scope systems and users enrolled in MFA	100% internet-facing; >=99% overall	<100% internet-facing	IAM	Weekly
KPI	Internet-facing security review	% registered web properties with current annual review	100%	<95 %	Security Architecture	Monthly
KPI	Corrective actions closed on time	% actions closed by agreed date	>=95%	<90%	GRC	Monthly
KRI	Unmanaged assets	Count of discovered assets not in managed inventory	0	>0	CIO / Asset Management	Weekly
KRI	Overdue critical exceptions	Count of critical exceptions past due	0	>0	CISO	Daily/Weekly

Type	Metric	Calculation	Target	Threshold	Owner	Frequency
KRI	Internet-facing systems without MFA	Count of internet-facing systems not protected by MFA	0	>0	IAM	Daily
KRI	Unapproved cross-zone rules	Count of firewall rules without current owner/business justification	0	>0	Network Security	Monthly
KRI	Detection time for high-severity events	Median time from first malicious activity to alert	<4 hours Tier 1; <24 hours Tier 2	Above target	SOC	Monthly

Model dashboard

Measure	Status	Model result
Asset inventory coverage	Amber	Discovery found three unregistered assets; owners assigned.
Internet-facing MFA coverage	Red	One critical exception remains open.
Critical exceptions past due	Red	One item exceeded its target date.
Firewall review completion	Amber	92% reviewed; target is 100%.
High-severity detection time	Green	Median 2.5 hours after new alert rules.
Corrective actions on time	Green	96% closed by due date.

Escalation rules

- Any internet-facing system without MFA: notify CISO and risk owner immediately; restrict access until approved compensating controls are in place.
- Critical exception past due: executive escalation within one business day and weekly tracking until closure.
- Unmanaged asset discovered: classify, assign owner and place into applicable control programs within two business days.
- Repeated threshold breach for two reporting periods: present to the Technology Risk Committee with a funded corrective plan.

Question answers

Question / topic	Model answer
Why tool count weak?	It measures capability purchased, not whether all assets are covered or controls are effective.
Completeness metric	Count or percentage of discovered assets not matched to the managed inventory.

Question / topic	Model answer
Exception warning	Number and age of overdue high/critical exceptions.
Critical breach response	Immediate escalation, containment or restriction, accountable owner and time-bound remediation.

Task 9: Conduct the Incident Tabletop and Present to Executives

Suggested time: 120 minutes · **Primary lead:** Incident Lead with all students participating

Required outputs

Tabletop decision log; communication matrix; one-page executive report; five-minute presentation.

Facilitation notes

- Release injects one at a time. Do not allow teams to rewrite earlier decisions after seeing later facts; they may update decisions with a documented rationale.
- Grade clarity of decisions and escalation more heavily than technical vocabulary.

Model answers

Tabletop inject answer guide

Inject	New fact	Expected response
Inject 1	SOC confirms unusual login to an internet-facing microsite using a valid employee account.	Disable or reset the account; isolate the server; preserve logs; declare a high-severity incident; assign incident commander; identify owner and connections.
Inject 2	Forensics identifies connections from the microsite to multiple internal servers.	Block unnecessary paths; segment affected systems; review privileged credentials; expand investigation; notify CISO, Legal and executive leadership.
Inject 3	Evidence indicates access to a customer contact database and about 90 servers.	Assess data scope and materiality; involve Privacy, regulators and law enforcement; prepare disclosure; preserve evidence; determine customer-protection actions.
Inject 4	No account numbers, passwords or Social Security numbers are confirmed stolen.	Communicate accurately without minimizing the event; state confirmed data, unknowns, actions and monitoring; avoid claiming zero risk.

First four hours

- Activate the incident response plan and appoint an incident commander.
- Contain the compromised account and server while preserving forensic evidence.
- Determine affected systems, data, accounts and network paths.

- Engage Legal, Privacy, Compliance and law enforcement as appropriate.
- Start an executive decision log and establish update cadence.
- Apply temporary controls to similar internet-facing systems and review MFA exceptions.

Model communication matrix

Audience	Information	Timing	Owner
Executive leadership / Board	Scope, customer impact, business disruption, regulatory exposure, decisions and resources	Every 2-4 hours initially	CISO / Incident Commander
Legal / Compliance / Privacy	Data involved, jurisdictions, materiality, notification deadlines and evidence	Continuous during scoping	Incident Commander
Regulators / SEC	Material verified facts, timing, impact and remediation	Per applicable requirements	Legal / Corporate Secretary
FBI / Law enforcement	Indicators, evidence and suspected criminal activity	Promptly after confirmation	Legal / CISO
Employees	Required credential resets, phishing awareness and operational instructions	As actions are approved	Internal Communications
Customers	Confirmed data affected, protective steps and contact channels	After facts and obligations are validated	Corporate Communications / Legal

Model executive report

Section	Model content
Situation	Attackers gained access through an internet-facing Corporate Challenge server that was omitted from the enterprise MFA upgrade and used the foothold to access approximately 90 servers.
Impact	Names, addresses, phone numbers and email addresses for 76 million households and 7 million small businesses were accessed. No financial account data, passwords or Social Security numbers were confirmed stolen.
Root cause	Incomplete asset inventory, ineffective control-exception management and inadequate segmentation between a low-criticality web property and internal customer systems.
Actions taken	Containment, credential resets, forensic investigation, law-enforcement coordination, vulnerability closure, data scoping and executive/regulatory communication.
Decisions needed	Approve enterprise internet-facing asset review, mandatory MFA exception closure, segmentation remediation, formal exception governance and independent assurance testing.
Lesson	Security capability does not create assurance unless governance confirms complete control coverage across every in-scope asset.

Question answers

Question / topic	Model answer
Interrupt operations?	When continued operation materially increases data loss, attacker access, safety risk or regulatory exposure; use the least disruptive containment that is effective.
Verify before communication	Affected systems, data categories, population, timeline, containment status, known fraud, legal obligations and remaining uncertainty.
Executive approvals	Major shutdowns, public disclosure, material risk acceptance, funding, vendor or service termination and overdue critical exceptions.
Single lesson	Governance completeness and exception management are necessary to ensure security controls apply everywhere they are required.

Suggested Final Scorecard

Task	Points	Primary criteria
1	10	Case comprehension, plain language and questions.
2	10	Timeline accuracy and stakeholder understanding.
3	12	Inventory completeness, control scope and ownership.
4	12	Cause-event-impact risk statements.
5	12	Consistent scoring and defensible rationale.
6	12	Framework mapping and evidence.
7	14	Corrective actions, exception governance and RACI.
8	8	Useful metrics, thresholds and escalation.
9	10	Decision quality and executive communication.

Total

100 points. In team delivery, use the task score for the group deliverable and a separate individual contribution score based on role output, participation and quality review.